>>> BSidesSP

Apple Red Team Village (ARTV)

Vamos fazer funcionar no Windows

Mac a gente vê depois

Integrando macOS em arquiteturas pensadas para Windows — sem fingir que é só 'mais um endpoint'.



Natalia Sampaio • BSidesSP • 17/05



Conheça seu Mac

As diferenças que quebram o ‘é só mais um endpoint’

1



ABM + ADE

Mac corporativo nasce no Apple Business Manager; não é imagem padrão e join no improviso.

2

Perfis MDM



Configuração vem por perfil: política, restrição, Wi-Fi, certificado e compliance.

3

Keychain + Certificados



A confiança mora no keychain; certificado no lugar errado vira Wi-Fi que não conecta.

4

FileVault



Criptografia é nativa e conversa com recovery, escrow e operação.

5

TCC / PPPC



Permissão de tela, disco, câmera e automação não é detalhe; sem isso o app instala, mas não funciona direito.

6

System Extensions



VPN, rede e segurança no macOS moderno dependem de extensões aprovadas.

7

Gatekeeper + Notarização



Aplicativo fora do fluxo pode ser barrado mesmo “funcionando no Windows”.

8

Atualização e ciclo de vida



macOS tem ritmo, suporte e transições próprias; upgrade sem preparo vira chamado.

Se você tentar tratar Mac igual Windows, cada endpoint vai ter que ser tratado como uma exceção operacional

Ciclo de Vida do Mac

O fluxo ideal vs. o que realmente acontece em ambiente Windows-first



Fluxo ideal

1. **Compra + ABM**
   
   Mac entra no Apple Business Manager.
2. **ADE + MDM**
   
   Enrollment automático e supervisão.
3. **Identidade**
   
   SSO, acesso e autenticação integrados.
4. **Certificados**
   
   Wi-Fi, VPN e trust entregues por perfil.
5. **Compliance**
   
   Baseline, EDR e políticas aplicadas.
6. **Suporte + Offboarding**
   
   Operação, troca e descarte controlados.

Fluxo realista

1. **Compra freestyle**
   
   Nem sempre veio pelo fluxo certo.
2. **MDM mais ou menos**
   
   Perfil chega, some ou chega pela metade.
3. **Identidade dividida**
   
   Office funciona; login local vive em outro universo.
4. **Certificado Schrödinger**
   
   No portal existe; no Wi-Fi a verdade aparece.
5. **Compliance oráculo**
   
   Está non-compliant, mas ninguém sabe por quê.
6. **Suporte arqueológico**
   
   O time caça evidência em sete consoles.

Onde o fluxo quebra

- ABM / ADE
- Grupos e atribuição
- Keychain e trust
- NDES / PKCS / Wi-Fi
- Logs e ownership



Se o Mac não entra no ciclo de vida certo, ele vira endpoint gerenciado na teoria e exceção operacional na prática.

As engrenagens invisíveis

O Mac tem camadas que trabalham nos bastidores.
Quando você entende cada uma, o caos vira controle.



ABM + ADE



A base de tudo. Coloca o Mac direto na sua gestão desde o primeiro boot.

Quando usar:
Sempre. Sem isso, você está remando contra a maré.

Perfis MDM



Políticas, restrições, Wi-Fi, certificados, extensões e muito mais. O cérebro da operação.

Quando usar:
O tempo todo. Padrão, segurança e produtividade em escala.

Keychain + Certificados



Autenticação forte, assinaturas e confiança mútua. Sem isso, nada seguro funciona.

Quando usar:
Sempre que precisar de acesso, Wi-Fi corporativo, VPN, SSO, assinaturas e criptografia.

FileVault



Criptografia nativa que protege os dados mesmo se o Mac cair na mão errada.

Quando usar:
Sempre. Dispositivo perdido não pode virar vazamento.

ALERTA: Se uma dessas camadas falhar, o Mac até liga — mas acesso, rede, compliance e suporte viram ruído operacional.

O custo do “quebra-galho”

Tratar Mac com método Windows gera retrabalho, riscos e perda de tempo.



Configurações quebradas



Políticas e perfis mal aplicados quebram funcionalidades do macOS ou não são respeitados.

Impacto:
Instabilidade, usuários frustrados e mais chamados no suporte.

Falta de visibilidade e controle



Sem ABM, inventário e telemetria adequados, você opera no escuro.

Impacto:
Decisões erradas, mudanças arriscadas e zero previsibilidade.

Riscos de segurança



Credenciais, certificados e criptografia mal gerenciados abrem portas para ataques e vazamentos.

Impacto:
Incidentes de segurança e exposição de dados.

Retrabalho constante



Sem automação e padronização, cada Mac vira um caso único que consome tempo.

Impacto:
Equipes sobrecarregadas e produtividade lá embaixo.

Experiência do usuário ruim



Atualizações quebram fluxos, apps não funcionam e o usuário perde a confiança na TI.

Impacto:
Queda de produtividade e perda de confiança na TI.



ALERTA: Sem abordagem nativa para Mac, o que era para ser uma exceção vira a regra: mais risco, mais custo e mais dor de cabeça para todos.

Mac não quebra em componente

Ele quebra na integração



O problema raramente é 'falta de peça'. O problema é quando MDM, identidade, certificados, rede e recovery param de conversar.



Identidade + login local

IdP, Company Portal e conta local precisam manter contexto e senha coerentes.

Quando a integração quebra:

- A senha muda no diretório, mas o Mac continua preso no estado antigo.



ABM + ADE + Intune

Ownership, enrollment e atribuição de perfis dependem do fluxo completo, não só do MDM existir.

Quando a integração quebra:

- O dispositivo entra gerenciado "na teoria", mas recebe política pela metade.



NDES / PKCS + Keychain

Emitir certificado não basta; ele precisa chegar no keychain certo, com trust e uso corretos.

Quando a integração quebra:

- O certificado existe no portal, mas não serve para autenticar de verdade.



Certificado + Wi-Fi / ISE / VPN

Acesso corporativo depende da cadeia completa: certificado, trust, rede e validação do lado servidor.

Quando a integração quebra:

- O Mac até liga, mas não entra na rede que faz o ambiente funcionar.



FileVault + escrow + suporte

Criptografia, recovery key escrow e processo operacional precisam andar juntos.

Quando a integração quebra:

- Você tem disco protegido, mas sem recuperação previsível e sem saída limpa.

ALERTA: Em Mac, o incidente quase nunca nasce num componente sozinho. Ele nasce na passagem de contexto entre plataformas.

O Mac não quebra em componente, quebra em integração.

Pequenas falhas de comunicação entre serviços geram grandes problemas.

Pense no Mac como um sistema orquestrado: hardware, software e serviços trabalhando em conjunto.
Quando a integração falha, os sintomas aparecem em cascata.



Regra de ouro:
Diagnostique a integração, não apenas a peça.

A natureza integrada do macOS

O macOS é um ecossistema onde tudo conversa o tempo todo.
Se um elo falha, o efeito se espalha.

Hardware
(T2/Apple Silicon, NVRAM, sensores)

↔

Sistema
(macOS, drivers, extensões)

↔

Segurança
(FileVault, Secure Enclave, SIP)

↔

Serviços
(iCloud, IdP, Apple Services)

↔

Usuário
(contas, senhas, perfis, permissões)

Sintomas comuns de falhas de integração

Pede senha o tempo todo
Falha de confiança entre serviços.

iCloud com erro ou lento
Descompasso de autenticação.

Login não sincroniza
Conflito entre Local e IdP (ex.: AD/Azure).

Atualizações travadas
Serviços de fundo não conseguem se comunicar.

Recursos que somem
Permissões, perfis ou serviços fora de sincronia.

Exemplos de falhas de integração

Senha correta, mas não entra	Desalinhamento entre senha local e do IdP. Conciliação falha.
FileVault pede a todo momento	Instabilidade no token de desbloqueio ou no volume de recuperação.
iCloud não sincroniza	Problema de identidade e tokens de sessão com Apple Services.
SSO funciona em alguns apps, não em outros	Extensões, perfis ou certificados não distribuídos de forma consistente.
iMessage/FaceTime indisponível	Serviços com credenciais ou validações divergentes.

Como pensar e diagnosticar

1. Reproduza o cenário com o usuário.
2. Levante logs relevantes (Unified Log).
3. Verifique identidade e autenticação.
4. Confira perfis, extensões e certificados.
5. Teste conectividade e serviços Apple.
6. Corrija a causa da desincronia, não apenas o sintoma.

ALERTA: Trocar senha, reinstalar ou resetar pode mascarar. Entender a integração é resolver de verdade.
Menos reinstalações. Menos retrabalho. Mais resultado.

Entenda a integração → Ataque a causa raiz → Resultado sustentável

Configurações que fazem diferença

NDES e conciliação de senha: pequenos ajustes, grandes impactos.

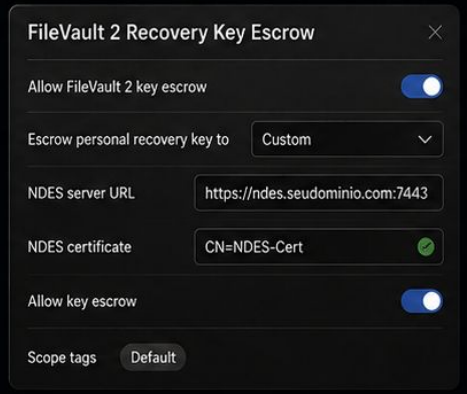


NDES: configure agora, agradeça depois

Sem NDES, o FileVault fica vulnerável a ataques de senha offline.

COMO CONFIGURAR O NDES

1. **No Intune:**
   Dispositivos > Configuração > Criar perfil > Templates > macOS Settings.
2. **Busque por:** FileVault 2 Recovery Key Escrow.
3. **Ative e preencha:**
   - NDES URL
   - NDES Certificate
   - Allow Key Escrow
4. **Atribua o perfil**
   e sincronize o Mac.



Dica: valide o certificado do NDES e garanta que a URL esteja acessível pelos Macs. Teste com um dispositivo antes de escalar.

Conflito de conciliação de senha?

Quando senha local e do IdP divergem, o Mac pode não conciliar.

COMO RESOLVER

1. **Identifique o conflito**
   Mensagem comum:
   "A senha não pode ser usada para desbloquear o disco."
2. **Verifique o usuário no diretório**
   Confirme se a senha no IdP está correta.
3. **Sincronize a senha no Mac**
   No Mac, abra o Company Portal > Dispositivo > Sincronizar.
4. **Forçar reconciliação (se necessário)**
   No Terminal (com o usuário logado):

```
dscl . -passwd /Users/$(whoami)
********
```

5. **Reinicie e teste**
   Reinicie o Mac e teste o login.

SINAIS DE CONFLITO

- Pedido constante de senha.
- FileVault não desbloqueia.
- Login funciona, mas recursos da empresa não.

BOAS PRÁTICAS

- Use senhas fortes e complexas.
- Oriente usuários a não alterar a senha só no Mac.
- Garanta sincronização após troca de senha.
- Monitore via Intune e logs de identidade.

ALERTA: Sem NDES, sua chave de recuperação não tem para onde ir. E sem conciliação, o usuário não entra, e o suporte não para. Configure, teste e monitore.



Senha local vs. senha corporativa

O IdP sabe a senha nova. O Mac talvez ainda não.

Quando a senha muda fora do Mac, a conta local pode continuar presa no hash antigo.
O problema aparece em login, FileVault, Company Portal e suporte.



Regra de ouro:
Reconcilie diretório, conta local e Secure Token — não só a senha do usuário.

A cadeia que precisa conversar

A troca de senha só fecha quando identidade, conta local e desbloqueio continuam contando a mesma história.

IdP / diretório	SSO / Company Portal	Conta local	Secure Token	Login / FileVault
A senha nova nasce aqui.	Sincroniza identidade do usuário.	Pode continuar com hash antigo.	Precisa seguir válido.	É onde a divergência aparece.

Sintomas comuns

- Pede senha o tempo todo
- Login local falha
- FileVault não desbloqueia
- Portal reclama de sync
- SSO funciona, login não

Exemplos de falhas de integração

Senha correta, mas não entra	Conciliação entre diretório e conta local não aconteceu.
FileVault pede a senha antiga	Token de desbloqueio ou volume local ficou preso no estado anterior.
Company Portal pede sincronização	O Mac ainda não refletiu a troca de senha do IdP.
SSO funciona em app, login local não	Identidade corporativa e conta local divergiram.
Usuário jura que trocou a senha	Provável desalinhamento entre IdP, conta local e token.

Como pensar e diagnosticar

1. Confirme a senha no diretório / IdP.
2. Valide qual conta está no login local.
3. Sincronize pelo Company Portal.
4. Verifique Secure Token e desbloqueio.
5. Reconcilie a senha com o usuário logado.
6. Reinicie e teste login + FileVault.

ALERTA: Resetar senha sem entender o fluxo só troca o sintoma de lugar.

Entenda a integração | Ataque a causa raiz | Resultado sustentável

FileVault

Criptografar é fácil. Recuperar é o problema.

Em Mac corporativo, FileVault não é só ativar criptografia.
Secure Token, recovery key, escrow e operação precisam fechar o ciclo.



Regra de ouro:
Sem escrow testado, você não tem recuperação gerenciada.

A cadeia que precisa conversar

FileVault só é seguro e operável quando habilitação, chave e processo andam juntos.

1. **Usuário com token** — Alguém precisa poder desbloquear o volume.
2. **FileVault ativo** — Criptografia habilitada de fato.
3. **Recovery Key** — A chave precisa existir.
4. **Escrow no Intune** — A chave precisa chegar de forma confiável.
5. **Suporte / playbook** — Recuperação precisa ser previsível.

Sintomas comuns

- Ativou, mas não escrovou
- Usuário sem token
- Ninguém acha a chave
- Offboarding trava
- Recovery vira improviso

Exemplos de falhas de integração

FileVault está ativo	Mas a recovery key não foi escrovada com sucesso.
Usuário é admin	Mas não possui Secure Token para operar o volume.
A chave existe	Mas ninguém sabe onde ela foi armazenada.
Troca de máquina / offboarding	Falha porque ownership e recuperação não foram definidos.
Incidente exige desbloqueio	O suporte improvisa porque o processo nunca foi testado.

Como pensar e diagnosticar

1. Verifique status real do FileVault.
2. Confirme Secure Token do usuário e do admin.
3. Valide geração e escrow da recovery key.
4. Teste recuperação em cenário controlado.
5. Defina ownership e playbook operacional.
6. Garanta fluxo de troca e offboarding.

ALERTA: Sem escrow e processo, você não tem criptografia gerenciada.
Você tem um cofre com chave perdida.

Entenda a integração · Ataque a causa raiz · Resultado sustentável

Intune para Mac

Perfil aplicado não significa estado resolvido.

Console verde ajuda, mas não fecha diagnóstico. Entre atribuição, entrega, aplicação e estado real, muito pode se perder.



Regra de ouro:
Estado real mora no endpoint e nos logs, não só na console.

A cadeia que precisa conversar

Um perfil só virou realidade quando grupo, payload, macOS e evidência contam a mesma história.

1	2	3	4	5
Grupo / atribuição	**Check-in / entrega**	**Aplicação macOS**	**Estado real**	**Evidência**
O alvo certo recebeu o perfil certo?	O payload chegou ao device?	O sistema aceitou ou bloqueou?	O recurso mudou no endpoint?	Há log, inventário e compliance explicáveis?

Sintomas comuns

- Assigned, mas não chegou
- Chegou, mas não aplica
- Console verde
- Compliance confuso
- Usuário reclama

Exemplos de falhas de integração

Perfil está assigned	Mas foi para o grupo errado ou incompleto.
Device fez check-in	Mas o payload não foi baixado ou processado.
Perfil chega	Mas o macOS bloqueia por extensão, TCC ou permissão.
Compliance aparece green	Mas o recurso ainda não mudou no endpoint.
Usuário reporta falha	Enquanto a console insiste que está tudo certo.

Como pensar e diagnosticar

1. Confirme atribuição e grupo alvo.
2. Valide check-in e entrega do payload.
3. Cheque se o macOS aceitou a configuração.
4. Teste o estado real no endpoint.
5. Colete logs e evidências locais.
6. Compare console, endpoint e experiência do usuário.

ALERTA: Console verde não é evidência suficiente. Estado real mora no endpoint e nos logs.

Entenda a integração · Ataque a causa raiz · Resultado sustentável

Troubleshooting raiz

Pare de reinstalar e comece a seguir evidência.

Em Mac, reinstalar costuma mascarar a causa. Diagnóstico bom segue as camadas: log, perfis, trust, rede, identidade e agente.



Regra de ouro:
Hipótese antes de reset. Evidência antes de formatação.

A cadeia que precisa conversar

Antes de mexer, descubra em qual camada a história parou de fechar.

Unified Log	Profiles	Keychain / trust	Rede / serviços	Identidade / agente
O macOS contou.	O perfil existe e está válido?	Certificado e confiança batem?	DNS, Wi-Fi, VPN e ISE respondem?	Conta, token e extensão estão coerentes?

Sintomas comuns

Wi-Fi falha · SSO estranho · App some · Compliance diverge · VPN só em alguns Macs

Exemplos de falhas de integração

Wi-Fi falha	Olhe certificado, trust e ISE antes de reinstalar.
SSO funciona em parte	Valide identidade, token e sincronização.
Aplicativo não abre direito	Pode faltar PPPC, system extension ou permissão.
Console e usuário discordam	Compare console, endpoint e log local.
VPN só funciona em alguns Macs	Teste proxy, DNS, cadeia de trust e perfil.

Como pensar e diagnosticar

1. Reproduza o problema com o usuário.
2. Colete Unified Log e horário do evento.
3. Inspecione perfis e payloads ativos.
4. Valide keychain, certificado e trust.
5. Teste conectividade e serviços dependentes.
6. Confirme a hipótese e só então corrija.

ALERTA: Reinstalar sem hipótese é formatação gourmet.
Diagnóstico bom reduz reincidência.

Entenda a integração · Ataque a causa raiz · Resultado sustentável

Arquitetura-alvo

Mac como parte do ambiente, não exceção gourmet.

Escalar Mac exige dono por camada, fluxo claro e evidência operacional.
Sem isso, cada endpoint vira projeto paralelo.



Regra de ouro:
Cada camada precisa de owner, integração e evidência.

As camadas que precisam existir

O Mac só escala quando a arquitetura inteira reconhece que ele existe.

1	Governança	ABM, ownership, grupos e ciclo de vida.
2	Identidade	IdP, SSO, MFA, conta local e recuperação.
3	Confiança	CA, NDES/PKCS, keychain, trust e certificados.
4	Rede	Wi-Fi, VPN, ISE, DNS, proxy e serviços internos.
5	Endpoint	MDM, perfis, EDR, FileVault, TCC/PPPC.
6	Operação	Logs, playbooks, suporte, métricas e offboarding.

Exemplos de falhas de integração

ABM existe	Mas ownership e atribuição não fecham o ciclo de vida.
SSO está pronto	Mas conta local e recuperação ficaram fora do desenho.
CA emite certificado	Mas trust, NDES ou keychain não sustentam o uso.
Wi-Fi corporativo existe	Mas depende de cadeia que o Mac não recebeu direito.
Suporte atende Mac	Mas sem logs, playbook e ownership vira improviso.

Como saber que escala

1. ABM e ADE fecham o onboarding.
2. Identidade cobre SSO, local e recuperação.
3. CA / NDES / PKCS funcionam ponta a ponta.
4. Rede valida Wi-Fi, VPN e ISE de verdade.
5. Endpoint aplica MDM, EDR e FileVault com evidência.
6. Operação tem logs, playbooks e offboarding testados.

ALERTA: O Mac escala quando a arquitetura tem dono, fluxo e evidência — não quando vira favor do suporte.

Entenda a integração | Ataque a causa raiz | Resultado sustentável

Checklist de sobrevivência

Antes de culpar o usuário, o Wi-Fi ou a Apple.

O mínimo operacional para o ambiente não virar suporte artesanal.



Regra de ouro:
Se não dá para provar, não dá para operar em escala.

Tem que estar certo

Configuração mínima para o Mac não nascer como exceção operacional.

- [ ] Mac no ABM
- [ ] ADE configurado
- [ ] Perfis MDM atribuídos
- [ ] Certificado emitido e confiável
- [ ] FileVault com escrow
- [ ] SSO e senha reconciliados

Tem que ser observável

Sem evidência, qualquer conclusão vira chute.

- [ ] Logs disponíveis
- [ ] Inventário confiável
- [ ] Estado real validado
- [ ] Playbook de suporte
- [ ] Processo de troca / offboarding
- [ ] Exceções documentadas

Tem que ter dono

Cada camada precisa saber quem responde por ela.

- [ ] ABM / MDM
- [ ] Identidade
- [ ] CA / NDES
- [ ] Rede / ISE / VPN
- [ ] Endpoint / EDR
- [ ] Operação / help desk

ALERTA: Se não dá para provar, não dá para operar em escala.

Entenda a integração

Ataque a causa raiz

Resultado sustentável

Mac não é difícil

Difícil é integrar depois.

Quando o Mac entra tarde na arquitetura, cada máquina vira exceção.
Quando entra no ciclo de vida, vira endpoint gerenciável.



Regra de ouro:
Entenda as camadas, valide as integrações e documente o caminho feliz e o quebrado.

O que vimos

Os pontos que mais geram incidentes e ruído operacional.

- Mac quebra em integração, não em peça.
- Ciclo de vida importa.
- Certificados e senha precisam fechar ponta a ponta.
- Console não substitui evidência local.
- FileVault sem escrow é sucesso de mentirinha.

O que fazer amanhã

Ações práticas para sair do modo improviso.

- Revisar ABM, ADE e atribuição de MDM.
- Testar NDES / PKCS ponta a ponta.
- Validar reconciliação de senha e Secure Token.
- Testar escrow e recuperação do FileVault.
- Criar playbook com log, hipótese e evidência.

O que leva embora

Se fizer direito, o resultado é operacional e técnico.

- Menos improviso.
- Menos exceções.
- Menos retrabalho.
- Mais previsibilidade.
- Mais escala com menos dor.

ALERTA: Se o Mac entra no ciclo de vida certo, ele deixa de ser exceção e vira operação.

Entenda a integração | Ataque a causa raiz | Resultado sustentável